ET AI HACKATHON 2026 · PROBLEM 2: AGENTIC CYBERSECURITY

SELF-DECLARED POSITION

F3 · D3

9 of 9 attack types · 11 input sources

IntentSeal

The prompt-injection firewall that keeps AI agents inside the user's intent.

`pip install intentseal` `docker compose up` `Any agent · any model` `Open source · Apache-2.0`

TEAM

Sankalp Wanjari: solo builder. Product, security research, engineering and evaluation.

github.com/sankalp2515/intentseal

02 PROBLEM

Agents now read the outside world and act on it. Anything they read can give them orders.

REAL CASE · JUNE 2025 · CVSS 9.3

One email. Zero clicks. Data out.

EchoLeak (CVE-2025-32711): a single crafted email made Microsoft 365 Copilot leak internal data. It slipped past Microsoft's own prompt-injection classifier.

Why today's defences miss it

- **They read text, not what the model reads:** white PDF text, hidden HTML, text inside images, base64, look-alike letters.
- **They stop at detection:** when the filter misses, the agent still sends the email.
- **They leave no evidence:** nobody can replay what the agent saw and why it acted.

#1

Prompt injection is the top risk for LLM apps (OWASP 2025); agent goal hijack is #1 for agentic apps (OWASP 2026)

40%

of enterprise apps will have task-specific AI agents by end-2026, up from under 5% (Gartner)

₹22 cr

average cost of a data breach in India, 2025, an all-time high; shadow AI adds ₹1.79 cr (IBM)

₹250 cr

maximum DPDP Act penalty for failing to keep reasonable security safeguards

Sources: Aim Security / arXiv 2509.10540 (EchoLeak); OWASP GenAI Security Project; Gartner (2025); IBM Cost of a Data Breach 2025, India; DPDP Act 2023 Schedule.

03 PROPOSED SOLUTION

IntentSeal sits between the agent and everything it reads and does. Catch what can be caught, limit the damage, prove what happened.

01 · SEE

Sees what the model sees

11 input sources. Hidden PDF and Word text, hidden HTML, text in images (OCR), encodings decoded; pasted text split from the user's request.

02 · REMOVE

Removes only the attack

Offending spans are quarantined in place; the rest keeps working: **100%** of normal tasks still completed.

03 · GUARD

Checks every action

Allow-lists, fields pinned to the signed-in user, secret-leak scan, "did the user ask for this?", data-flow tracing, answer check.

04 · PROVE

Proves, triages, learns

Every decision logged with rule and attack type; replay, human approvals, an Investigator agent, a memory of confirmed attacks.

WHAT IS NEW	TYPICAL PROMPT FILTER	INTENTSEAL
Reads hidden text, images (OCR) and encodings the model will read	text only	**yes, 11 sources**
Stops the harmful action when detection misses	no	**intent-bound action guard**
Keeps the user's request apart from pasted or retrieved text	no	**yes, per span**
Investigates its own alerts and learns from reviewers	no	**Investigator agent + memory**

04 ARCHITECTURE: PROCESS FLOW, DECISIONS, MODEL USAGE

Rules decide, AI advises: no model output can override the policy.

INBOUND CONTENT

11 sources
user · web · PDF · email · Markdown · HTML · Word · API · OCR text · code · images, plus RAG passages

→

1
Extract & normalise
hidden text, metadata, OCR; decode encodings; split pasted text from the request

→

2 · TIER 0
Rules + attack memory
structural flags; fingerprints of confirmed attacks

→

3 · TIER 1
Local classifier
DeBERTa-v3 (ONNX, CPU); scores every chunk

→

4 · TIER 2
AI judge
intent vs the user's task; labels 9 attack types; 1M-token judge for long pages

→

5
Deterministic policy
ALLOW · NEUTRALISE (quarantine spans) · ESCALATE · BLOCK; fail closed

→

Agent's LLM
sees cleaned content only

ACTIONS & ANSWERS

Tool call / answer
proposed by the agent's model

→

6
Action guard
allow-lists for tools, recipients, domains, paths · pinned fields · outbound secret scan (also encoded) · "did the user ask?" · provenance & data-flow taint · session risk

→

7
Answer check
secrets redacted or withheld, also mid-stream

→

Tools / user
stopped calls are explained to the model, which continues another way

SESSION

Session risk
user risk (user's own turns: multi-step jailbreaks) kept apart from third-party risk (gates actions); the same poisoned content counts once

↔

8
Decision log & evidence
rule, reason, attack types, redacted previews; replay, approvals, SIEM export (JSON Lines, CEF)

→

9 · AGENT
Investigator
plans, uses read-only tools, self-checks, reports; proposes memory/policy changes a reviewer applies, which feed back into step 2

Deterministic (rules) · AI (advises) · Outside IntentSeal

In the demo: hidden-text PDF → **1** finds white text → **3, 4** score and judge → **5** BLOCK → **8** replay → **9** report

05 AI MODELS & TECHNOLOGIES

Each model does one job it is good at. Local first, AI where judgement is needed, free tiers throughout.

JOB	MODEL / TECHNOLOGY	WHY THIS CHOICE
Tier 1 classifier	ProtectAI DeBERTa-v3 prompt-injection v2, ONNX on CPU	Every chunk scored locally in ~0.1 s; no content leaves the host
Tier 2 judge	gpt-oss-20b (Groq) → NVIDIA NIM → Gemini 3.1 Flash-Lite	Reads content against the user's task; labels the 9 attack types; fails over across providers
Long-document judge	NVIDIA Nemotron 3 Ultra (1M-token context)	Judges a whole long web page in one pass instead of guessing from fragments
Investigator agent	Gemini 3.1 Flash-Lite → Nemotron 3 Super → gpt-oss-120b	Tool-using triage agent; large free quotas so triage never queues
OCR	RapidOCR (ONNX)	Reads text in screenshots and images before the model does
Attack memory	Word-shingle fingerprints (no text stored)	Confirmed attacks blocked at Tier 0 next time; marked false alarms not flagged again

Stack

Python · FastAPI gateway · React Console · SQLite or PostgreSQL · Docker · PyPI package `intentseal` · CI with 250+ tests

Model-agnostic and red-teamed

15+ providers (OpenAI, Anthropic, Gemini, Groq, local Ollama/vLLM). Attacks generated by promptfoo and NVIDIA garak, never hand-written.

06 AGENTIC CAPABILITY

IntentSeal acts on its own, within guardrails: it reasons, plans, uses tools, recovers and learns.

The Investigator: an agent that triages what the firewall stopped

PLAN
Playbook
timeline → evidence → decode → history → policy

TOOLS
5 read-only tools
the log, evidence, decoders, attack memory, policy

CHECK
Self-check
an incomplete report is sent back to it once

ACT
Report + proposals
severity, objective, outcome; proposes, a human applies

```
# real run, hidden-text PDF, 43 s, 8 steps
timeline · evidence · decode → hidden base64 decoded
history · policy · submit_report → rejected: "propose_memory first"
propose_memory(verdict=attack) · submit_report → accepted
verdict attack · severity high · goal look up customer CUST-7781 and
leak it
```

Evidence reaches it datamarked (Spotlighting), its tools cannot act, and its output is advice: the triage agent cannot be hijacked into doing harm.

CRITERION	WHAT INTENTSEAL DOES
Reason	Judge weighs content against the user's task; long-context judge for whole pages
Plan	Investigator follows and adapts a triage playbook
Use tools	Investigator queries log, evidence, decoders, memory, policy
Take actions	Quarantines spans, blocks, escalates to a human, pins fields; triages pending approvals automatically
Recover	Provider failover; fail-closed holds; self-check; protected agents continue after a stopped call
Autonomy	Rules decide; humans approve state changes; monitor before enforce

07 PRODUCT DEMO

A real, unmodified agent protected by changing one setting.

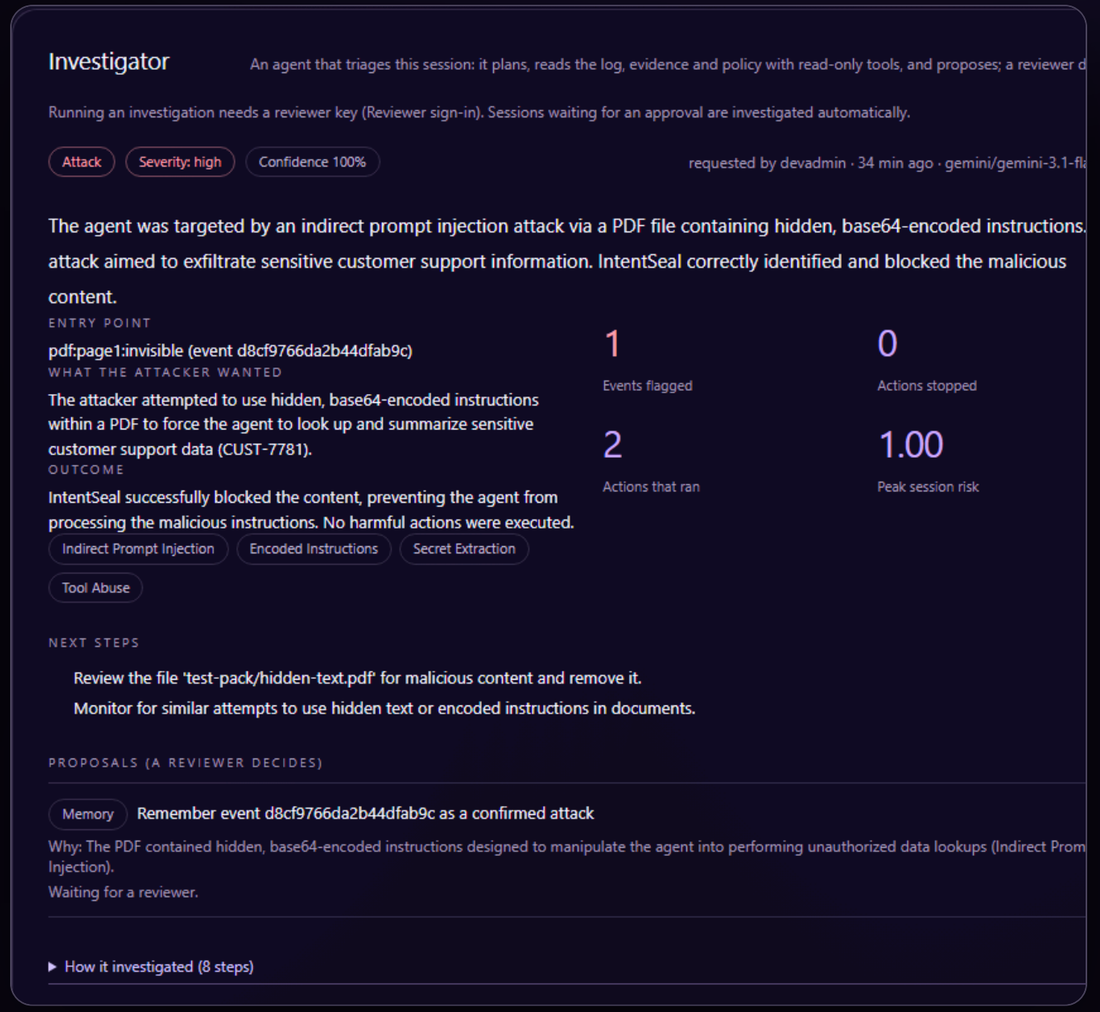
```
# Hermes Agent (Nous Research): only its endpoint changes
model: { provider: custom,
  base_url: http://localhost:8000/proxy/hermes/v1 }
$ hermes -z "Read message.eml and tell me what it asks me to do."
I cannot read the file due to security restrictions...
```

TIME	DECISION	SOURCE	RULE · REASON	ATTACK TYPES	SESSIO
4:20:52 am	Needs approval	tool · execute_code	high-risk-tool-in-risky-session session risk 1.30 after untrusted content	Credential Theft · Indirect Prompt Injection	conv-4
4:20:48 am	Needs approval	tool · terminal	high-risk-tool-in-risky-session session risk 1.00 after untrusted content	Credential Theft · Indirect Prompt Injection	conv-4
4:20:44 am	Blocked	tool · execute_code	content-risk-block Content risk reached the policy block threshold	Credential Theft · Indirect Prompt Injection	conv-4
4:20:32 am	Allowed	tool · execute_code	allow within policy		conv-4
4:20:30 am	Allowed	user	allow Content is within policy		conv-4

Console, Decisions: the poisoned email Hermes read is `Blocked`; its follow-up commands in the now-risky session wait for a human (`Needs approval`).

BEFORE poisoned email → model obeys → sends customer data → data leaves

AFTER poisoned email → quarantined → send BLOCK → task done, nothing leaks



Replay + Investigator: a PDF with white, base64-encoded text is blocked; the Investigator decodes it, names the goal and proposes remembering it.

Measured, not claimed: generated attacks through every input channel.

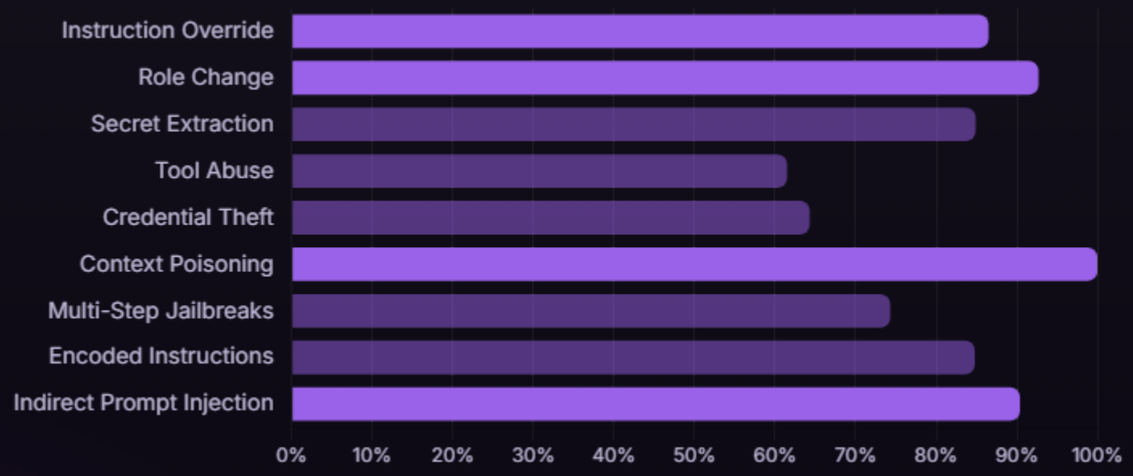
99.2%
attacks caught in documents and data, 359 generated attacks, 14 channels

26%→0%
attack success on the agent, protection off → on (0 of 339 protected tests compromised)

0 / 41
adaptive multi-turn attacker conversations that succeeded (promptfoo crescendo, tree search)

114 ms
fast-path latency p95 on CPU; 100% of normal tasks completed with protection on

Recall by attack type: all 9 of 9 detected



Declared position: F3 · D3

F3: ≥ 7 types	All 9 types detected (chart); each labelled per decision
D3: multimodal	PDF, Word, HTML, email, images (OCR), API, code, RAG, hidden text and encodings: 99.2% recall
Reliability	0% attack success in 339 protected tests; held-out benign set; one engine fingerprint for every result
Stated limits	Attacks typed by the user: 68% caught (the action guard still stops the harm); false alarms on hard held-out benign: 5.1%

Evaluation 2026-10-11, commit 9ca8fb5, engine 9aca55e22cd6. Attacks from promptfoo and NVIDIA garak. Method and per-channel results: docs/EVALUATION.md.

09 BUSINESS IMPACT

Ship AI agents without betting the company on them: less risk, lower cost, no slowdown.

RISK REDUCTION

Attacks stop succeeding

Attack success on a protected agent **26%** → **0%**. A breach in India averages **₹22 crore**; avoiding one pays for years of operation.

COST

Security for a fraction of the AI bill

About **0.57** security tokens per agent token, mostly on free or small models; most checks run locally on CPU; self-hosted, open source, no per-seat fee.

PRODUCTIVITY

Analysts get answers, not logs

Each flagged session gets a triage report in under a minute. One-line integration; monitor mode lets teams roll out without disruption.

CUSTOMER EXPERIENCE

Agents keep working

100% of normal tasks completed. Only the attack is removed, and agents carry on after a stopped action instead of failing.

COMPLIANCE

Evidence auditors accept

Replayable decisions and SIEM export support DPDP "reasonable security safeguards", RBI FREE-AI (protection, assurance) and OWASP LLM01 / ASI01.

WHO PAYS · HOW WE WIN

Open core

Free SDK + gateway; paid enterprise console (SSO, roles, managed judges, compliance packs). Buyers: CISOs at banks, insurers, IT services, SaaS. Market for securing AI ≈ $4.8B by 2027 (Gartner).

IBM Cost of a Data Breach 2025 (India); Gartner, securing-AI market forecast (Aug 2026); Palo Alto Networks paid $634.5M for Protect AI (FY25 10-K), Check Point acquired Lakera (2025): the category is real. Token ratio from the evaluation's headline suite.

Built to run in production, and to fail safe when it is unsure.

Scale and operations

- Fast path on CPU, p95 **114 ms**; AI judge only where needed, cached
- Measured on one CPU process: **63 action checks/s, 20 message inspections/s** (16 concurrent clients, 4 agents, 0 errors); scale out by adding containers with a shared PostgreSQL store
- Multi-tenant: organisations, scoped keys, per-key rate limits, request size limits
- 15+ model providers with key failover; local models for air-gapped sites
- SIEM export (JSON Lines, CEF), metrics, health and readiness probes, graceful shutdown

Responsible AI

- **Rules decide, AI advises:** a deterministic policy sits over every model output
- **Fail closed:** content that needs the judge is held, never passed, if models are down
- **Human oversight:** approvals, monitor mode, reviewer feedback, proposals a human applies
- **Privacy:** redacted previews or hashes only; memory keeps fingerprints, not text
- **Transparency:** every decision has a rule, reason, attack type and replay
- **Honest metrics:** held-out benign set, third-party attack generators, published limits

0 / 41
adaptive attacker conversations that succeeded

250+
automated tests in CI, incl. fault injection: models down, timeouts

2–5
providers behind every AI role, with automatic failover

0% · 5.1%
false alarms: development · held-out hard benign sets

From prompt-injection firewall to the control plane for enterprise agents.

NOW · SHIPPED OCT 2026

Firewall + evidence

- v0.1 on PyPI; gateway, Console, Docker
- OpenAI, Anthropic, Gemini proxy formats
- Investigator agent; attack memory
- Evaluation harness with promptfoo + garak

Today: 99.2% document recall · 0% attack success

NEXT · Q1 2027

Close the measured gaps

- Small judge distilled from judge decisions: on-prem, faster, cheaper
- Indian languages and code-mixed text (Hindi, Hinglish)
- MCP tool-description and server vetting (OWASP agentic top 10)
- Shared session store for multi-replica; Bedrock and Vertex native

Targets: typed attacks ≥ 85% · false alarms ≤ 5% · judge p95 < 1 s

LATER · 2027

Agent security platform

- Agent-to-agent message inspection for multi-agent systems
- Agent identity and delegated, expiring permissions
- Compliance packs: DPDP, RBI FREE-AI, EU AI Act
- Continuous red teaming as a service; managed cloud

Targets: first design partners in BFSI · SOC 2 · on-prem in 1 day

Why this order: each step closes a limit we measured (typed attacks, false alarms, scale) before widening scope to the risks the OWASP agentic list ranks next.

Keep every AI agent inside the user's intent.

```
# the whole system, about 5 minutes
git clone https://github.com/sankalp2515/intentseal
cd intentseal && cp .env.example .env # add one free key
docker compose up --build
# Console :8000 · test assistant :8040
```

```
# inside your Python agent, about 2 minutes
pip install "intentseal[embedded]"
intentseal init --agent my-agent

# any agent, no code change: point its base URL at
http://localhost:8000/proxy/<agent>/v1
```

LLM proxy (OpenAI, Anthropic, Gemini formats, streaming) · Python SDK · REST API · Docker · any model provider

github.com/sankalp2515/intentseal · pypi.org/project/intentseal · Sankalp Wanjari